

CWE AI Working Group: Existing Entry Modifications

Meeting Minutes

July 18, 2025

Attendance

Monika Akbar	Martin Hodo	Ahmed Nagy
Erick Galinkin	Steve Christey	Adarsh Adelli
Lee Szilagyi	Chris Gourley	
Michael Simon	Sazadur Rahman	

Agenda

- Status Updates
- Hyperparameter Submission Development
- Work Planning

Meeting Notes:

Status Updates: Steve announced that the next CWE release will be version 4.18, expected sometime in August.

- **Hyperparameter Submission Development:** The group has been focusing on the "insecure hyperparameters" submission, specifically refining a demonstrative example. The demonstrative example is intended to be a theoretical, educational scenario, with recent focus on "package hallucination" as a case study.
 - There was productive discussion in the last meeting about potential demonstrative examples, and work began on enhancing one of these.
 - The goal for today's meeting is to finish drafting a strong demonstrative example of insecure hyperparameters.

This document includes content generated with the assistance of Microsoft Teams Copilot, a generative AI tool. Microsoft Teams Copilot was used to generate the initial draft of the meeting minutes and provide suggestions for summarizing key discussion points. All AI-generated content has been reviewed and edited by the CVE Program prior to publishing. Please report any inaccuracies or other issues to the CVE Program.

- The next working group meeting is scheduled for August 15th, after Black Hat and DEF CON, before the next CWE release, providing a final opportunity for review.

Hyperparameter Submission Development: *New Entry Development: ES2406-9e5cf10: Insecure Setting of AI/ML Model Inference Parameters.*

- **Demonstrative Example for Insecure Hyperparameters:** Steve and the team discussed the structure and content of the demonstrative example focusing on insecure inference parameters and their implications. There was a discussion on setting the temperature parameter too high, which could lead to excessive, erroneous, or unexpected outputs.
 - **Example Structure:** Includes introductory text, bad code design and examples, explanation of the weakness, and good code to fix the weakness.
 - **Insecure Parameters:** Discussion on setting the temperature parameter too high, which could lead to excessive, erroneous, or unexpected outputs.
 - **Package Hallucination Example:** The team decided to focus on package hallucination for the demonstrative example, emphasizing the use of a generic term for the AI coding assistant (e.g., AI-assisted IDE or AI coding assistant) to ensure broader applicability.
 - **Risks of Hallucination:** Discussion of risks such as malicious packages introduced by hallucinated libraries, which the example will highlight.
 - **Programming Language:** Python was chosen for the example due to its popularity and well-known package management frameworks.
 - **Configuration File and Temperature Setting:** The importance of correctly setting the temperature parameter to avoid hallucination was discussed.
 - The group discussed including a disclaimer noting that the solution does not guarantee complete elimination of package hallucination. This would mean including a configuration file with a temperature below default (e.g., 0.8) and guardrails to test package presence and trustworthiness (e.g., checking package age and registration date).

- **Work Planning:** Steve thanked everyone and reminded the team to coordinate on slides and follow-ups.

Action Items:

- **Example Code for Demonstrative Example:** Follow up with Erick to obtain a small amount of code from garak that can be used to show package hallucination in the demonstrative example. (Steve)
- **Final Review and Discussion:** Conduct a final review and discussion on the draft text explaining the weakness.